

REPÚBLICA CÍVICA DE ASTERIA

ESTRATEGIA NACIONAL DE RESILIENCIA Y CIBERDEFENSA

2026–2032

Continuidad del Estado · Infraestructuras críticas · Defensa digital

2032

HORIZONTE

revisión intermedia en 2029

4·24·72

NOTIFICACIÓN

incidentes graves

72 h

MODO DEGRADADO

capacidad mínima objetivo

2 años

EJERCICIO NACIONAL

más ejercicios sectoriales

Aprobada por Acuerdo del Directorio Nacional de 22 de septiembre de 2026
Signatura: SEG-AST · ENRC/2026-2032 · Edición pública

00 · APROBACIÓN Y NATURALEZA

Una estrategia nacional, no una habilitación excepcional

La Estrategia Nacional de Resiliencia y Ciberdefensa 2026–2032 constituye el marco de planificación del Estado para prevenir, resistir, responder y recuperarse de incidentes capaces de interrumpir funciones esenciales, con especial atención a las amenazas digitales y a la interdependencia entre redes, energía, comunicaciones, transporte, salud, finanzas y administración pública.

La Estrategia orienta programas, presupuestos, regulación técnica, contratación y ejercicios nacionales. No amplía por sí misma las potestades de vigilancia, intervención o uso de la fuerza. Toda medida que afecte derechos fundamentales requerirá base legal específica, necesidad, proporcionalidad, supervisión y posibilidad de revisión.

REGLA CONSTITUCIONAL

La seguridad no convierte una medida en lícita por sí sola. El Estado debe poder proteger los servicios comunes sin transformar la prevención del riesgo en una autorización general para vigilar a las personas.

La ejecución corresponde a los órganos competentes conforme a la Constitución, la legislación sectorial y los Presupuestos Generales. El Directorio Nacional publicará un informe anual de progreso y someterá la Estrategia a revisión intermedia en 2029.

Contenido

- 01 · Resumen ejecutivo
- 02 · Lecciones nacionales: 1986 y 2011
- 03 · Alcance y conceptos
- 04 · Entorno estratégico 2026
- 05 · Doctrina y principios
- 06 · Gobernanza y mando
- 07 · Funciones esenciales y criticidad
- 08 · Arquitectura nacional de ciberseguridad
- 09 · Administración pública y servicios digitales
- 10 · Infraestructuras críticas y OT
- 11 · Identidad, datos y criptografía
- 12 · Cadena de suministro y dependencia tecnológica
- 13 · Gestión de incidentes y continuidad
- 14 · Defensa nacional en el ciberespacio
- 15 · Ciudadanía, empresas y comunicación pública
- 16 · Talento, investigación e industria
- 17 · Cooperación internacional
- 18 · Programa de medidas 2026–2032
- 19 · Financiación y contratación
- 20 · Indicadores, auditoría y revisión
- Anexos · sectores críticos, niveles de incidente y cuadro de objetivos

Resistir sin dejar de funcionar

Asteria adopta esta Estrategia sobre una premisa sencilla: una sociedad avanzada no puede prometer que nada fallará. Puede, en cambio, diseñar sus instituciones para que un fallo técnico, un ataque, una tormenta o la pérdida de un proveedor no derriben simultáneamente los servicios de los que depende la vida cotidiana.

La experiencia nacional ofrece dos referencias. La Crisis de los Tres Días de 1986 mostró cómo fallos físicos y organizativos pueden amplificarse cuando las competencias son confusas y la información no llega a quien debe decidir. El ciberataque sistémico de 2011 demostró que la digitalización crea nuevas eficiencias y, al mismo tiempo, dependencias capaces de cruzar sectores en minutos.

CICLO NACIONAL DE RESILIENCIA



La resiliencia no consiste en evitar todo fallo, sino en impedir que un fallo local se convierta en una crisis nacional.

Figura 1. Ciclo nacional de resiliencia.

La estrategia no separa artificialmente ciberseguridad y continuidad. La identidad digital depende de telecomunicaciones; los hospitales dependen de energía y proveedores; la red eléctrica depende de sistemas industriales y comunicaciones; las finanzas dependen de tiempo, identidad, datos y conectividad. La resiliencia nacional se gestiona, por tanto, como una red de dependencias.

Objetivo	Línea estratégica	Resultado perseguido
1	Continuidad de funciones esenciales	Que el Estado y los operadores críticos puedan seguir prestando un servicio seguro, aunque sea degradado, durante una crisis.
2	Defensa digital común	Elevar un nivel mínimo obligatorio y verificable de ciberseguridad en administración e infraestructuras críticas.
3	Detección y mando temprano	Reducir el tiempo entre compromiso, conocimiento, decisión y coordinación intersectorial.
4	Recuperación comprobada	Sustituir planes que “existen en papel” por capacidades restauradas periódicamente en ejercicios reales.
5	Dependencias controladas	Conocer proveedores, software, comunicaciones, energía y servicios cuya pérdida puede generar riesgo sistémico.
6	Capacidad humana y tecnológica	Asegurar talento, investigación, industria y reservas de capacidad suficientes para no depender de improvisación en crisis.
7	Seguridad compatible con libertad	Rechazar puertas traseras generales, vigilancia indiscriminada y automatización sin responsable humano.

02 · LECCIONES NACIONALES

1986 enseñó coordinación; 2011 enseñó interdependencia

La Crisis de los Tres Días de 1986 no fue un único accidente. Una tormenta extrema, inundaciones, un fallo de red y un incidente industrial coincidieron mientras organismos distintos esperaban autorizaciones o discutían competencias. Las pérdidas se agravaron por avisos ignorados, información fragmentada y ausencia de un mando de continuidad capaz de priorizar funciones esenciales.

El ciberataque de 2011 no produjo víctimas mortales, pero interrumpió durante horas servicios bancarios, hospitalarios y de transporte. La investigación posterior identificó cuatro fragilidades estructurales: credenciales reutilizadas o insuficientemente protegidas, segmentación deficiente entre dominios, excesiva concentración de servicios digitales comunes y planes de recuperación que nunca habían sido probados a escala.

LECCIÓN 1986

Una institución puede cumplir su procedimiento y, aun así, contribuir a un fracaso sistémico si nadie es responsable del resultado conjunto.

LECCIÓN 2011

La continuidad digital no consiste en proteger cada ordenador. Consiste en impedir que una dependencia común pueda detener al mismo tiempo hospitales, pagos, transporte y administración.

Desde 2011 Asteria ha mejorado la segmentación, la gestión de identidad, la capacidad de respuesta y la coordinación público-privada. La presente Estrategia consolida esas reformas y las extiende a cadenas de suministro, servicios en nube, inteligencia artificial, sistemas industriales y continuidad física.

03 · ALCANCE Y CONCEPTOS

Resiliencia como capacidad operativa

A efectos de esta Estrategia, resiliencia es la capacidad de una organización o sistema para anticipar riesgos, soportar degradación, mantener funciones esenciales, recuperarse dentro de objetivos definidos y aprender del incidente. Ciberdefensa es el conjunto de capacidades del Estado destinadas a proteger redes, sistemas y funciones frente a acciones hostiles en el ciberespacio, incluida la defensa militar cuando corresponda.

La Estrategia se aplica a la Administración nacional y orienta a las administraciones regionales y locales. Las obligaciones para operadores privados derivarán de la legislación de infraestructuras críticas, comunicaciones, datos, finanzas, energía, salud, transporte y demás normas aplicables.

Concepto	Criterio operativo
Función esencial	Servicio cuya interrupción prolongada amenaza vida, seguridad, derechos fundamentales, estabilidad económica o continuidad constitucional.
Operador crítico	Entidad pública o privada responsable de una función o activo cuya pérdida puede generar impacto grave o sistémico.
Activo crítico	Sistema físico, digital, humano o de suministro necesario para una función esencial.
Modo degradado	Forma segura de continuar una función con menor capacidad cuando los sistemas ordinarios no están disponibles.
Dependencia crítica	Proveedor, tecnología, red o recurso cuya indisponibilidad puede bloquear una función sin sustitución suficientemente rápida.

Concepto	Criterio operativo
Incidente sistémico	Evento que atraviesa varios sectores o amenaza simultáneamente múltiples funciones esenciales.

04 · ENTORNO ESTRATÉGICO 2026

Más digitalización, más concentración, más superficie común

El riesgo nacional no procede únicamente de actores hostiles. Un error de configuración, una actualización defectuosa, una inundación, el fallo de un centro de datos o la insolvencia de un proveedor pueden producir efectos comparables a un ataque deliberado. La planificación se basa en consecuencias y dependencias, no solo en intenciones.

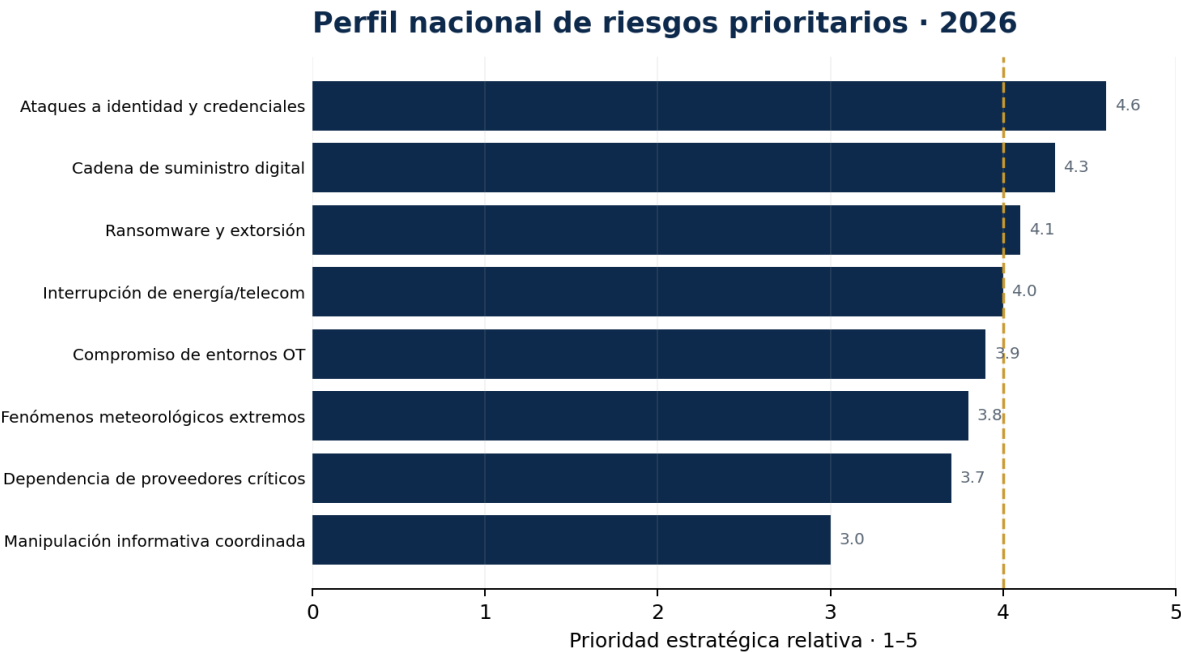


Figura 2. Priorización estratégica relativa para 2026. No representa probabilidad estadística.

Los ataques contra identidad y credenciales siguen siendo la vía más transversal de acceso. El crecimiento de servicios compartidos y proveedores tecnológicos concentra riesgo; una única plataforma puede convertirse en dependencia para centenares de organismos. En entornos industriales, la convergencia entre tecnología operacional y redes corporativas aumenta eficiencia, pero exige separar claramente seguridad, disponibilidad y control remoto.

La inteligencia artificial amplía tanto la automatización defensiva como la capacidad de generar fraude, suplantación y código malicioso. La Estrategia evita tratar la IA como categoría aislada: se exigirá responsabilidad, trazabilidad y validación proporcional al impacto del sistema donde se utilice.

05 · DOCTRINA Y PRINCIPIOS

Seguridad que sigue funcionando cuando el plan falla

Principio	Aplicación
Resiliencia por diseño	La continuidad se define al diseñar un servicio, no después de sufrir la caída.
Mínimo privilegio y separación	Accesos, redes y funciones se separan para que un compromiso no implique control total.

Principio	Aplicación
Responsabilidad humana	Toda decisión de alto impacto, también la automatizada, mantiene un responsable identificable.
Recuperación demostrable	Una copia de seguridad que nunca se restaura no se considera capacidad de recuperación.
Diversidad y sustitución	Se evita que un único proveedor, protocolo o centro concentre una función nacional sin alternativa.
Transparencia compatible con seguridad	Se publica lo necesario para control y aprendizaje sin revelar detalles que faciliten ataques.
Privacidad y criptografía fuerte	La protección colectiva no requiere debilitar de forma general las comunicaciones privadas.
Aprendizaje sin ocultación	Los fallos se investigan para corregir causas; ocultar un incidente para proteger métricas constituye riesgo institucional.

La Estrategia adopta una política de “fallo contenido”: asumir que cualquier componente puede fallar o ser comprometido y limitar la propagación, mantener funciones mínimas y reconstruir desde un estado conocido.

06 · GOBERNANZA Y MANDO

Un responsable claro antes de que empiece la crisis

El Director Nacional conserva la responsabilidad política última por la continuidad del Estado. La coordinación ordinaria corresponde al Directorio de Seguridad, que mantiene la arquitectura nacional de resiliencia y convoca al Consejo Nacional de Resiliencia cuando un riesgo excede la capacidad de un solo sector.

Órgano	Función principal	Límite
Directorio Nacional	Fija prioridades, declara crisis nacionales y asigna recursos extraordinarios.	No puede ampliar por estrategia las potestades que requieran ley.
Directorio de Seguridad	Coordina resiliencia civil, protección de infraestructuras y respuesta intersectorial.	No dirige la operación técnica interna de cada operador salvo habilitación de emergencia.
Centro Nacional de Respuesta Cibernética (AST-CERT)	Alerta, coordinación técnica, asistencia, análisis y enlace con equipos sectoriales.	No ejerce funciones policiales ni inteligencia sobre ciudadanos por defecto.
Comando de Ciberdefensa	Protege redes de defensa y ejecuta misiones militares autorizadas en el ciberespacio.	Opera bajo cadena militar, derecho aplicable y control civil.
Autoridades sectoriales	Fijan requisitos específicos para energía, salud, finanzas, transporte y otros sectores.	Deben respetar el marco nacional y evitar obligaciones contradictorias.
Operadores críticos	Gestionan su riesgo, notifican incidentes, mantienen continuidad y participan en ejercicios.	La designación crítica no transfiere al Estado la gestión ordinaria de la empresa.

El Consejo Nacional de Resiliencia reúne, cuando sea necesario, Seguridad, Energía, Sanidad, Infraestructuras, Economía, Defensa, administración territorial y responsables de operadores críticos. Su secretaría técnica mantiene un mapa vivo de dependencias nacionales y un registro de decisiones durante incidentes sistémicos.

MANDO DE CRISIS

En un incidente sistémico debe quedar explícito quién decide prioridades nacionales, quién coordina la respuesta técnica y quién mantiene cada servicio. La coordinación no sustituye la responsabilidad del operador.

07 · FUNCIONES ESENCIALES Y CRITICIDAD

Priorizar por consecuencias, no por prestigio institucional

Cada organismo y operador crítico clasificará sus funciones por impacto y dependencia. La etiqueta de “crítico” se aplicará con prudencia: incluirlo todo impide priorizar. La clasificación nacional se revisará al menos cada dos años.

Nivel	Descripción	Objetivo de continuidad
C0 · Constitucional	Mando del Estado, comunicaciones de emergencia, alertas nacionales y funciones constitucionales indispensables.	Operación continua o restablecimiento inmediato mediante medios alternativos.
C1 · Esencial vital	Emergencias, energía mínima, agua, atención hospitalaria urgente, comunicaciones prioritarias.	Capacidad degradada segura durante al menos 72 h y recuperación prioritaria.
C2 · Esencial social	Pagos, transporte principal, suministro sanitario, administración crítica, logística alimentaria.	Recuperación sectorial definida y alternativas manuales o regionales.
C3 · Importante	Servicios cuya interrupción es grave pero tolerable durante periodos limitados.	Recuperación programada según análisis de impacto.

La continuidad de una función no exige mantener toda su comodidad habitual. Durante una crisis, el objetivo puede ser procesar menos pagos, operar menos trenes, limitar servicios administrativos o priorizar consumo eléctrico. La degradación planificada es preferible a la caída no controlada.

08 · ARQUITECTURA NACIONAL DE CIBERSEGURIDAD

Una defensa común con ejecución distribuida

AST-CERT mantiene la alerta nacional, comparte indicadores, coordina incidentes de alcance intersectorial y presta asistencia a entidades que superen su capacidad. Los sectores de gran tamaño podrán mantener equipos de respuesta propios interoperables con AST-CERT.

La arquitectura técnica se apoya en identidad fuerte, segmentación, inventario de activos, telemetría suficiente, protección de privilegios, copias de seguridad aisladas, respuesta reproducible y capacidad de reconstrucción. Ningún producto concreto constituye por sí mismo cumplimiento.

Control mínimo	Requisito 2032
Identidad privilegiada	Autenticación resistente a phishing, separación de cuentas y revisión periódica de privilegios.
Inventario	Todo sistema crítico con propietario, función, versión, dependencia y clasificación conocidos.
Segmentación	Separación demostrable entre usuarios, administración, producción, OT y entornos de recuperación.
Registro	Telemetría suficiente para reconstruir acciones relevantes, con conservación proporcional al riesgo.
Copias y restauración	Copias aisladas o inmutables y restauraciones completas ensayadas al menos anualmente.
Gestión de vulnerabilidades	Priorización por exposición y criticidad; plazos reforzados para fallos explotados activamente.
Respuesta	Procedimientos ensayados, contactos 24/7 para incidentes graves y capacidad de preservar evidencia.

Control mínimo	Requisito 2032
Proveedores	Inventario de dependencias, cláusulas de notificación, continuidad y derecho de auditoría proporcional.

09 · ADMINISTRACIÓN PÚBLICA

El Estado no puede exigir a otros lo que no practica

La Administración nacional adoptará un Marco Mínimo de Resiliencia Digital obligatorio para sistemas C0, C1 y C2. Las entidades con menor capacidad podrán consumir servicios comunes seguros, pero conservarán un responsable institucional por sus datos, accesos y continuidad.

- Eliminar autenticación heredada en sistemas críticos salvo excepción temporal documentada.
 - Mantener cuentas de administración separadas y estaciones de acceso privilegiado para sistemas de mayor criticidad.
 - Probar restauración y operación degradada antes de considerar un plan de continuidad como aprobado.
 - Diseñar servicios ciudadanos con alternativas ante caída de identidad digital, conectividad o proveedor en nube.
 - Publicar inventarios de sistemas automatizados de alto impacto sin revelar configuraciones explotables.
 - Incluir portabilidad, acceso a datos, continuidad y salida del proveedor en contratos tecnológicos críticos.
- Los organismos no podrán ocultar incidentes para proteger indicadores de rendimiento. Los cuadros de mando distinguirán prevención, detección, impacto y recuperación; un aumento de incidentes reportados puede reflejar mayor capacidad de detección y no necesariamente deterioro de seguridad.

10 · INFRAESTRUCTURAS CRÍTICAS Y OT

Seguridad digital sin olvidar que una válvula sigue siendo física

Energía, agua, industria, transporte y edificios críticos emplean sistemas de control cuya prioridad incluye seguridad física y disponibilidad. La aplicación mecánica de controles diseñados para oficina puede aumentar el riesgo operacional. Cada operador mantendrá ingeniería de seguridad conjunta entre personal de proceso, mantenimiento y ciberseguridad.

Área OT	Exigencia estratégica
Arquitectura	Zonas y conducciones documentadas; separación entre control, supervisión, oficina y acceso remoto.
Acceso remoto	Deshabilitado por defecto donde no sea necesario; acceso temporal, autenticado, registrado y revocable.
Inventario	Equipos, firmware, comunicaciones, dependencias y repuestos críticos conocidos.
Cambios	Pruebas previas y ventanas adaptadas al proceso; excepción justificada cuando parchear sea inseguro.
Respuesta	Procedimientos que prioricen seguridad del proceso y eviten apagar sistemas sin comprender consecuencias.
Operación manual	Capacidad de operar funciones esenciales de forma local o degradada cuando sea técnicamente posible.
Proveedores	Acceso de mantenedores controlado; contratos con obligaciones de vulnerabilidades y fin de soporte.

Área OT	Exigencia estratégica
Ejercicios	Simulaciones conjuntas entre ingeniería, operaciones, emergencias, dirección y ciberseguridad.

Para sistemas industriales de larga vida útil, el Estado promoverá compensaciones técnicas, segmentación y renovación escalonada en lugar de exigir sustituciones indiscriminadas que puedan crear riesgo adicional o dependencia de un solo fabricante.

11 · IDENTIDAD, DATOS Y CRIPTOGRAFÍA

La confianza digital empieza por saber quién puede hacer qué

La identidad es una infraestructura nacional transversal. Los sistemas públicos críticos deberán separar identidad ciudadana, identidad de personal e identidades de máquina, limitar la confianza entre dominios y disponer de procedimientos de acceso de emergencia auditables.

Asteria protege el uso de criptografía fuerte. La Estrategia no contempla puertas traseras generales, claves maestras obligatorias ni debilitamiento deliberado de estándares para facilitar acceso estatal. Las investigaciones individuales utilizarán las facultades legales específicas disponibles y estarán sometidas a control judicial cuando proceda.

Los datos necesarios para respuesta a incidentes se recogerán con finalidad definida, conservación limitada y controles de acceso. La ciberseguridad no justificará la construcción indiscriminada de historiales permanentes de actividad personal.

PRINCIPIO CRIPTOGRÁFICO

Una vulnerabilidad deliberada creada para “los buenos” sigue siendo una vulnerabilidad disponible para cualquiera que consiga explotarla.

12 · CADENA DE SUMINISTRO

No existe soberanía si una única avería puede detener el país

La estrategia de suministro no busca autarquía tecnológica. Busca conocer concentraciones, mantener sustitución razonable y conservar capacidad para operar cuando un proveedor falle, sea adquirido, pierda soporte o resulte comprometido.

Las compras críticas identificarán subproveedores relevantes, ubicación de servicios, dependencias de actualización y mecanismos de soporte.

Los contratos incluirán notificación de incidentes, portabilidad de datos, asistencia de salida y acceso técnico suficiente para auditoría.

Los organismos evitarán formatos propietarios que impidan migración cuando exista una alternativa interoperable razonable.

El Estado mantendrá reservas o contratos de prioridad para equipamiento cuya reposición sea lenta y cuya pérdida comprometa C0 o C1.

Los proveedores de software crítico deberán mantener prácticas de desarrollo seguro y, cuando sea exigible, información de componentes suficiente para gestionar vulnerabilidades.

La diversificación se evaluará por función. Contratar dos empresas que dependen del mismo servicio subyacente no cuenta como redundancia real.

13 · GESTIÓN DE INCIDENTES Y CONTINUIDAD

Notificar pronto, decidir pronto, recuperar con orden

Los incidentes graves de operadores críticos seguirán un esquema 4-24-72. La primera notificación dentro de cuatro horas desde que exista conocimiento razonable del carácter grave será breve y operacional; a las veinticuatro horas se remitirá una evaluación inicial; a las setenta y dos horas, una actualización técnica y de impacto. La ausencia de datos completos no justificará retrasar el aviso inicial.

Nivel	Criterio orientativo	Coordinación
N1 · Local	Impacto limitado, controlado por una entidad, sin afectación sostenida a función esencial.	Gestión del operador; notificación sectorial si procede.
N2 · Sectorial	Interrupción significativa, riesgo de propagación o afectación de varios operadores del mismo sector.	Autoridad sectorial + AST-CERT.
N3 · Nacional	Afecta varios sectores, regiones o funciones CO/C1; requiere priorización nacional.	Consejo Nacional de Resiliencia y mando nacional de continuidad.
N4 · Sistémico	Amenaza continuidad constitucional, seguridad nacional o funcionamiento general de servicios esenciales.	Directorio Nacional; coordinación civil-militar según naturaleza del incidente.

Las entidades preservarán evidencia cuando sea compatible con la seguridad y recuperación. La investigación forense no deberá retrasar medidas urgentes para proteger vidas o estabilizar procesos industriales.

En materia de ransomware, los organismos públicos no abonarán rescates con fondos públicos. Una excepción por riesgo inmediato para la vida requerirá autorización extraordinaria conforme a ley, intervención de seguridad y documentación completa. Los operadores privados críticos deberán notificar cualquier intención de pago cuando la legislación aplicable así lo establezca; el Estado no garantiza reembolso ni recuperación de fondos.

14 · DEFENSA NACIONAL EN EL CIBERESPACIO

Capacidad militar bajo control civil y jurídico

El Comando de Ciberdefensa protege las redes de defensa, presta apoyo a autoridades civiles cuando se active legalmente y mantiene capacidades para operaciones militares en el ciberespacio. La presente Estrategia no autoriza por sí misma operaciones ofensivas.

Toda operación con efectos fuera de redes propias exigirá autoridad jurídica y política conforme a su naturaleza, reglas de enfrentamiento, evaluación de proporcionalidad y trazabilidad de la decisión. La atribución pública de un ataque corresponde al nivel político y podrá combinar evidencia técnica, inteligencia y contexto diplomático.

La defensa nacional prioriza resiliencia, inteligencia técnica, protección de comunicaciones, continuidad de mando y apoyo a servicios esenciales por encima de una doctrina de “respuesta automática”. Un incidente digital no determina por sí solo el instrumento de respuesta; Asteria podrá responder por vías diplomáticas, judiciales, económicas, técnicas o militares según gravedad y evidencia.

15 · CIUDADANÍA, EMPRESAS Y COMUNICACIÓN PÚBLICA

La resiliencia también depende de información creíble

Durante una crisis, la comunicación oficial debe ser rápida, factual y corregible. El Estado distinguirá hechos confirmados, hipótesis y recomendaciones operativas. Ocultar incertidumbre para proyectar control deteriora la confianza cuando los hechos cambian.

La lucha contra campañas coordinadas de manipulación se centrará en atribución, exposición de operaciones, seguridad de cuentas, alfabetización mediática y comunicación institucional. La expresión legal no se convertirá en ilícita por ser falsa, ofensiva o incómoda; cualquier retirada o limitación de contenidos requerirá la base jurídica ordinaria aplicable.

El programa nacional para pymes ofrecerá guías, servicios compartidos, asistencia ante incidentes y esquemas de certificación proporcionados. La seguridad de la cadena de suministro no puede descansar únicamente en exigir a proveedores pequeños controles que no pueden financiar.

16 · TALENTO, INVESTIGACIÓN E INDUSTRIA

Capacidad soberana significa saber operar, no fabricar todo

Asteria mantendrá capacidad propia suficiente para comprender, auditar, integrar y recuperar tecnologías críticas. Ello no implica producir nacionalmente cada componente. La dependencia aceptable es aquella conocida, diversificada y sustituible dentro del tiempo que la función puede tolerar.

Línea	Medida 2026–2032
Talento público	Carrera técnica especializada, movilidad entre sectores, formación continua y bandas profesionales competitivas para puestos escasos.
Universidades y FP	Programas de seguridad de sistemas, redes, criptografía, OT, ingeniería de resiliencia y respuesta a incidentes.
Investigación	Financiación de seguridad de software, criptografía poscuántica, sistemas industriales, verificación y recuperación.
Industria	Compras públicas abiertas a proveedores nacionales y extranjeros bajo requisitos comunes de auditabilidad y continuidad.
Reserva técnica	Red voluntaria de especialistas acreditados activable en incidentes nacionales y ejercicios.
Divulgación	Programas de reporte de vulnerabilidades y recompensas donde resulten adecuados.

La política de vulnerabilidades parte de la divulgación coordinada. El Estado solo podrá retener temporalmente conocimiento de una vulnerabilidad no pública por una razón excepcional de seguridad nacional, mediante revisión formal, plazo definido y reevaluación periódica. La utilidad ofensiva no bastará por sí sola para justificar una retención indefinida.

17 · COOPERACIÓN INTERNACIONAL

Interdependencia sin automatismos de intervención

Asteria intercambiará alertas, indicadores, asistencia técnica y buenas prácticas con Estados y organizaciones asociadas. Los acuerdos buscarán interoperabilidad y ayuda mutua, sin transferir automáticamente decisiones soberanas sobre despliegue militar o acceso a datos.

La cooperación priorizará notificación transfronteriza de incidentes, respuesta a ciberdelincuencia, protección de cables y rutas de comunicación, seguridad de cadenas de suministro, ejercicios conjuntos y estándares abiertos. La asistencia a otro Estado se decidirá según capacidad, legalidad, proporcionalidad e interés público.

18 · PROGRAMA DE MEDIDAS 2026–2032

Treinta acciones con responsable y plazo

ID	Acción	Responsable principal	Plazo
A01	Marco Mínimo de Resiliencia Digital para Administración nacional	Seguridad / Estado digital	2027
A02	Registro nacional de funciones C0–C2 y dependencias críticas	Seguridad	2027

ID	Acción	Responsable principal	Plazo
A03	Implantación de MFA resistente a phishing en cuentas privilegiadas críticas	Todos los directorios	2027
A04	Inventario completo de activos críticos con propietario institucional	Todos los directorios	2028
A05	Programa nacional de restauración probada e inmutabilidad de copias	Estado digital / sectores	2028
A06	Norma de segmentación y acceso remoto para OT	Seguridad / Energía / Infraestructuras	2027
A07	Equipos sectoriales de respuesta interoperables con AST-CERT	Autoridades sectoriales	2028
A08	Esquema 4·24·72 de notificación para incidentes graves	Seguridad	2027
A09	Mapa nacional de proveedores y concentraciones tecnológicas críticas	Economía / Seguridad	2028
A10	Cláusulas de portabilidad, continuidad y notificación en compras críticas	Hacienda / Estado digital	2027
A11	Plan de operación degradada de comunicaciones de emergencia	Seguridad / Infraestructuras	2028
A12	Ejercicio nacional ASTER-RESILIENCIA cada dos años	Seguridad	2027–2031
A13	Ejercicios sectoriales anuales para C0 y C1	Autoridades sectoriales	desde 2027
A14	Reserva nacional de comunicaciones y terminales de emergencia	Seguridad / Defensa	2028
A15	Programa de continuidad de identidad y firma pública	Estado digital	2028
A16	Revisión de concentraciones en servicios de nube y DNS públicos	Estado digital / Competencia	2027
A17	Marco público de divulgación coordinada de vulnerabilidades	AST-CERT	2027
A18	Procedimiento formal de retención excepcional de vulnerabilidades	Seguridad / Justicia	2027
A19	Programa de ciberseguridad para pymes proveedoras críticas	Economía / AST-CERT	2028
A20	Reserva técnica nacional voluntaria	Seguridad / Función Pública	2028

ID	Acción	Responsable principal	Plazo
A21	Laboratorio nacional de seguridad OT y sistemas embebidos	Ciencia / Seguridad	2029
A22	Programa de criptografía poscuántica para sistemas de larga vida	Estado digital / Ciencia	2030
A23	Plan de recuperación del sistema financiero ante indisponibilidad digital	Economía / Finanzas	2028
A24	Capacidad manual/degradada en hospitales C1	Sanidad	2028
A25	Plan nacional de energía y telecomunicaciones cruzadas	Energía / Infraestructuras	2028
A26	Auditorías rojas y pruebas de penetración controladas en C0/C1	Seguridad / sectores	anual
A27	Informe público anual de resiliencia y métricas	Directorio Nacional	anual
A28	Revisión independiente postincidente N3/N4	Integridad / comisión ad hoc	obligatoria
A29	Revisión intermedia de la Estrategia	Directorio Nacional / Cámara	2029
A30	Evaluación final y estrategia sucesora	Directorio Nacional	2032

19 · FINANCIACIÓN Y CONTRATACIÓN

Presupuesto estable, no fondos de pánico

Los Presupuestos Generales de 2026 asignan 4,2 miles de millones de astras a ciberdefensa y resiliencia digital dentro de seguridad y defensa, y 2,4 miles de millones a ciberseguridad civil dentro del Estado digital. Estas cifras no representan todo el gasto nacional en resiliencia: sanidad, energía, agua, transporte y operadores privados financian capacidades sectoriales en sus propios programas.

La inversión derivada de esta Estrategia se integrará en presupuestos ordinarios y marcos plurianuales. Los fondos extraordinarios se reservarán para crisis o aceleraciones justificadas; no sustituirán mantenimiento, personal, renovación y ejercicios recurrentes.

Los proyectos críticos deberán incluir coste de operación, soporte, salida del proveedor y recuperación, no solo coste de adquisición.

Las compras de seguridad se evaluarán por reducción de riesgo verificable, interoperabilidad y capacidad de operación, no por acumulación de productos.

Las excepciones de contratación por emergencia deberán documentarse y revisarse una vez estabilizada la crisis.

Los contratos tecnológicos críticos incluirán obligaciones de cooperación durante incidentes y conservación de evidencia cuando sea legal y técnicamente viable.

20 · INDICADORES, AUDITORÍA Y REVISIÓN

Medir capacidad, no coleccionar números

El Directorio Nacional publicará un informe anual con indicadores de implantación, incidentes agregados, tiempos de recuperación, ejercicios, dependencias relevantes y recomendaciones. Los datos que aumenten materialmente la capacidad ofensiva contra un sistema podrán publicarse de forma agregada o diferida.

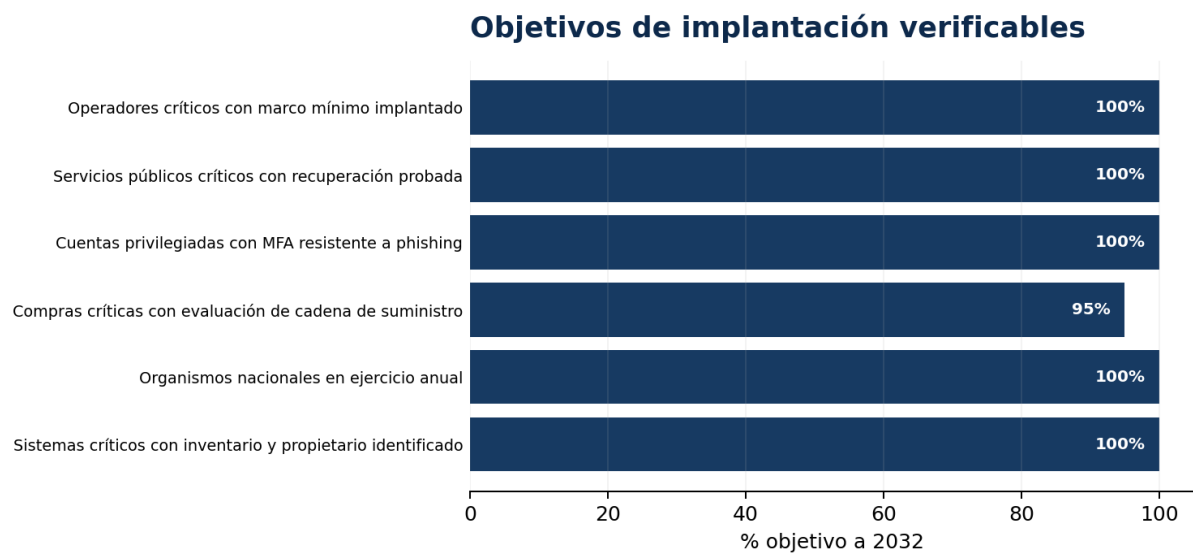


Figura 3. Objetivos verificables de implantación para 2032.

Indicador	Meta 2032	Evidencia
Operadores C0/C1 con marco mínimo implantado	100%	Auditoría o certificación sectorial
Servicios públicos C0/C1 con recuperación completa probada	100% anual	Prueba de restauración y acta
Cuentas privilegiadas críticas con MFA resistente a phishing	100%	Registro de identidad y auditoría
Compras críticas con evaluación de cadena de suministro	≥95%	Expediente de contratación
Organismos nacionales participantes en ejercicio anual	100% de C0/C1	Informe de ejercicio
Activos críticos con propietario y dependencia documentados	100%	Inventario validado
Incidentes N2+ con revisión de lecciones	100%	Informe postincidente
Incidentes N3/N4 con revisión independiente	100%	Informe público o resumen desclasificado

No se utilizará un único indicador como medida de “seguridad”. Reducir incidentes reportados puede significar mejora o, por el contrario, peor detección. La evaluación combinará preparación, exposición, detección, impacto, recuperación y aprendizaje.

REVISIÓN 2029

La revisión intermedia podrá modificar prioridades y metas sin alterar los principios de la Estrategia. Los cambios materiales se publicarán con justificación, impacto presupuestario y evaluación de derechos.

21 · ANEXO I

Sectores críticos nacionales

Sector	Alcance	Coordinación principal
Energía	electricidad, combustibles, nuclear, redes y almacenamiento	Energía
Agua	captación, tratamiento, distribución y saneamiento	Infraestructuras
Salud	urgencias, hospitales, medicamentos y sistemas clínicos	Sanidad
Comunicaciones	redes fijas, móviles, satélite, DNS y servicios esenciales de Internet	Infraestructuras / Estado digital
Finanzas	pagos, compensación, depósitos y mercados sistémicos	Economía
Transporte	ferrocarril, puertos, aviación y nodos logísticos	Infraestructuras
Alimentación y logística	distribución mayorista, frío y nodos de abastecimiento	Economía
Administración digital	identidad, firma, registros, Cívicos y servicios comunes	Estado digital
Defensa	mando, comunicaciones, logística y sistemas militares	Defensa
Emergencias	policía, protección civil, alertas y comunicaciones prioritarias	Seguridad
Industria estratégica	materiales, fabricación crítica, química y proveedores de defensa	Economía / Defensa
Conocimiento	centros de datos científicos y laboratorios nacionales con funciones críticas	Ciencia

22 · ANEXO II

Matriz de severidad para incidentes cibernéticos

Factor	Bajo	Medio	Alto	Sistémico
Personas	sin riesgo físico	impacto limitado	riesgo significativo	riesgo masivo o continuidad vital
Servicio	degradación local	interrupción relevante	C0/C1 afectado	múltiples C0/C1
Extensión	una unidad	varias sedes/operadores	varios sectores o regiones	nacional o transfronterizo
Duración	<2 h	horas	>12 h o recuperación compleja	días o incertidumbre alta
Control	contenido	requiere apoyo sectorial	requiere coordinación nacional	requiere mando nacional

La clasificación final será contextual. Un incidente breve puede ser N3 si afecta una función constitucional; un incidente técnicamente sofisticado puede permanecer en N1 si no produce impacto relevante.

23 · ANEXO III

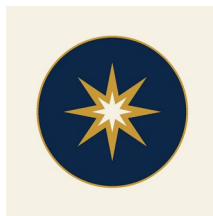
Calendario de implantación

Periodo	Prioridad
2026–2027	Gobernanza, registro de funciones críticas, notificación 4-24-72, identidad privilegiada, cláusulas de contratación, marco mínimo y norma OT.
2028–2029	Continuidad probada, mapa de proveedores, reserva técnica, equipos sectoriales, ejercicios nacionales, revisión intermedia y capacidad degradada sectorial.
2030–2031	Criptografía de nueva generación, reducción de dependencias concentradas, madurez industrial y consolidación de capacidades de recuperación nacional.
2032	Auditoría final, evaluación parlamentaria y técnica, publicación de resultados y aprobación de estrategia sucesora.

24 · ANEXO IV

Glosario mínimo

Término	Definición
AST-CERT	Centro Nacional de Respuesta Cibernética de Asteria.
C0–C3	Niveles nacionales de criticidad de funciones.
N1–N4	Niveles operativos de severidad de incidentes.
OT	Tecnología operacional utilizada para controlar procesos físicos.
MFA	Autenticación multifactor.
Modo degradado	Operación segura con capacidad reducida durante indisponibilidad.
RTO	Tiempo objetivo de recuperación de una función.
Dependencia crítica	Recurso o proveedor cuya pérdida puede bloquear una función esencial.



SCIENTIA · LIBERTAS · PROGRESSUS

*“La continuidad no es ausencia de fallo.
Es la capacidad de seguir siendo un Estado cuando algo falla.”*

ARCHIVO NACIONAL DE ASTERIA · SEG-AST · ENRC/2026-2032